

MODULE 29 · DOMAIN 3 - CONTINUOUS IMPROVEMENT FOR EXISTING SOLUTIONS

Threat Detection and Response

Detection is the easy half. Correlation and containment are the exam.

DOMAIN 3 of 4 EXAM WEIGHT 25% MODULE 29 of 44

Attackers do not produce one finding. They produce **eight, over twenty hours**, and the sequence is the incident.

GuardDuty protection plans

- ◆ **Foundational sources are always on:** CloudTrail management events, VPC flow logs and DNS logs.
- ◆ **Protection plans add sources:** S3, EKS, RDS, Lambda, Malware Protection for EC2 and for S3, and Runtime Monitoring.
- ◆ **On first enabling GuardDuty, every plan is switched on except Runtime Monitoring.**
- ◆ **A plan launched after you enabled GuardDuty is not enabled for you.** Older accounts quietly lag behind.

ON THE EXAM

That second rule is the one that bites. An account that turned GuardDuty on in 2023 is missing everything AWS has added since.

Extended Threat Detection

- ◆ **Correlates many signals into one critical-severity attack sequence finding**, rather than eight medium ones.
- ◆ Each finding carries an incident summary, an events timeline, **MITRE ATT&CK mapping** and remediation advice.
- ◆ **Automatically enabled at no extra cost**. Coverage grew to EKS in 2025, and to EC2 and ECS later that year.
- ◆ It correlates **within one account**, over roughly a 24-hour window. Cross-account attacks may not join up.

ON THE EXAM

Breadth of protection plans determines how much it can see. Without S3 Protection it cannot build a sequence involving S3 at all.

What a suppression rule actually does

- ◆ **A suppressed finding is still generated**, marked archived, kept 90 days and visible in the console.
- ◆ **It is not sent to Security Hub, S3, Detective or EventBridge**, so no automation ever sees it.
- ◆ **It does not trigger a malware scan, and it is not used as a signal for attack sequences.**
- ◆ So suppressing a noisy finding type quietly reduces what Extended Threat Detection can correlate.

ON THE EXAM

Suppression looks like tidying and behaves like removing a sensor. Suppress deliberately, and know what you have blinded.

Who does what

SERVICE	ANSWERS	SIGNAL IN THE SCENARIO
GuardDuty	Is something malicious happening?	Behaviour, credentials, network, runtime
Inspector	What is vulnerable?	CVEs in EC2, containers and Lambda
Macie	Where is sensitive data?	Classification and discovery in S3
Detective	What actually happened?	Investigation after a finding exists
Security Hub	How are we doing overall?	Aggregation and standards scoring
Firewall Manager	Are our controls applied everywhere?	WAF, Shield and Network Firewall at scale

ON THE EXAM

Detective never detects. It explains a finding that something else produced, which is the distinction most often tested.

From finding to contained

01

Detect

GuardDuty raises a finding, or an attack sequence.

02

Route

EventBridge matches the type and severity.

03

Contain

Isolate the resource without destroying it.

04

Investigate

Detective and the preserved evidence explain the rest.

ON THE EXAM

Containment and investigation pull against each other. Terminating the instance stops the attack and destroys the evidence.

Containing without destroying

- ◆ **Replace the security group with an isolation group** that permits nothing. The instance stays running and reachable to forensics.
- ◆ **Snapshot the volumes and capture memory before anything else.** Memory is gone the moment you stop the instance.
- ◆ **Revoke the instance role's sessions**, since stolen temporary credentials work from anywhere until they expire.
- ◆ Copy evidence to a separate forensics account that the compromised account cannot reach.

ON THE EXAM

Revoking sessions is the step people forget. Isolating the instance does nothing about credentials already exfiltrated from it.

Reading the scenario

THE SCENARIO SAYS

Many related findings across a long period

GuardDuty has been on for years, gaps found

We need to know what else the attacker touched

Vulnerabilities before images reach production

Contain the instance but keep the evidence

WAF rules missing in some accounts

IT IS POINTING AT

Extended Threat Detection attack sequences

Protection plans not auto-enabled since

Amazon Detective

Inspector scanning in ECR

Isolation SG, snapshot, revoke sessions

AWS Firewall Manager

ON THE EXAM

Ask whether the gap is detection, correlation, investigation or containment. Each has a different service.

Meridian Freight enabled GuardDuty organisation-wide in 2022 and has left it running since. A security review finds no malware findings for S3 uploads and no runtime findings for containers, despite both features being described in current AWS documentation. GuardDuty shows as enabled and healthy in every account.

What is the MOST likely explanation?

- ☐ A Protection plans released after GuardDuty was enabled are not turned on automatically for existing customers
- ☐ B GuardDuty must be disabled and re-enabled to pick up new features
- ☐ C Those features require Security Hub to be enabled first
- ☐ D The findings exist but are below the severity threshold shown by default

◆ PAUSE AND DECIDE

What is the MOST likely explanation?

- A

New plans are not auto-enabled

Documented behaviour. A plan launched after you enabled GuardDuty stays off until somebody enables it, and the console still reports healthy.
- B

Disable and re-enable

Would lose finding history and is unnecessary. Plans can be enabled individually at any time.
- C

Requires Security Hub

Security Hub aggregates GuardDuty findings. It is not a prerequisite for GuardDuty to generate them.
- D

Severity filtering

Would hide low-severity findings, not remove entire categories. Malware findings are not low severity.

THE SIGNAL

Enabled and healthy does not mean complete. A four-year-old GuardDuty deployment is missing four years of protection plans.

Over 20 hours, GuardDuty raised eight medium-severity findings in one account: anomalous credential use, unusual API discovery calls, creation of new access keys, a deleted CloudTrail trail, and several S3 object operations. Each was triaged separately and closed as probably benign.

It was later confirmed as a genuine data exfiltration incident.

What would have surfaced this as a single critical incident?

- ☐ A GuardDuty Extended Threat Detection attack sequence findings
- ☐ B Raising the severity threshold on all GuardDuty findings
- ☐ C Amazon Detective, reviewed daily
- ☐ D A CloudWatch alarm on GuardDuty finding count

◆ PAUSE AND DECIDE

What would have surfaced this as a single critical incident?

- A

Attack sequence findings
Correlates signals over time into one critical-severity finding with a timeline and MITRE mapping. Exactly the eight-signals-over-a-day case.
- B

Raise severity thresholds
The findings were genuinely medium individually. Inflating severity produces noise and does not express the relationship.
- C

Detective daily
Excellent once you know to investigate. Every finding was closed as benign, so nobody would have opened it.
- D

Alarm on finding count
Eight findings in 20 hours across a busy account is unremarkable. Volume is not the signal; the pattern is.

THE SIGNAL

The scenario lists the signals in MITRE order: credential access, discovery, persistence, evasion, exfiltration. That shape is the finding.

A team was overwhelmed by GuardDuty findings about a vulnerability scanner they run themselves, so they created a suppression rule for that finding type. Six months later, an attack sequence finding that should have included those signals was never generated. The suppressed findings are still visible in the GuardDuty console, marked archived.

What is the explanation, and what should change?

- ☐ A Suppressed findings are excluded from Security Hub, EventBridge, Detective and attack sequence correlation; narrow the rule instead
- ☐ B The suppression rule deleted the findings permanently
- ☐ C Attack sequences require Security Hub, which was not enabled
- ☐ D The suppression rule expired and needs recreating

◆ PAUSE AND DECIDE

What is the explanation, and what should change?

- A** Suppression excludes downstream, so narrow it

Suppressed findings are archived but not forwarded anywhere, and are not used as attack sequence signals. Scope the rule to the scanner's own resources.
- B** Findings deleted

The scenario states they are still visible, marked archived. Suppression archives; it does not delete.
- C** Security Hub required

Extended Threat Detection runs inside GuardDuty and is automatically enabled. Security Hub is a destination, not a prerequisite.
- D** Rule expired

Suppression rules do not expire. The rule worked exactly as designed, which is the problem.

THE SIGNAL

Suppression is not filtering a view. It removes the finding from every downstream consumer, including the correlation engine.

GuardDuty reports that an EC2 instance is communicating with a known command-and-control server. The security team's runbook says to terminate the instance immediately. Legal has asked that evidence be preserved for a possible prosecution, and the incident response team needs to know what the attacker did.

The instance has an instance profile with access to several S3 buckets.

What should the response be?

- ☐ A Terminate the instance immediately to stop the communication
- ☐ B Apply an isolation security group, snapshot the volumes, revoke the instance role's active sessions, and copy evidence to a forensics account
- ☐ C Stop the instance and leave it for the forensics team
- ☐ D Remove the instance profile and leave the instance running normally

◆ PAUSE AND DECIDE

What should the response be?

- A

Terminate immediately
Stops the attack and destroys volumes, memory and every trace of what happened. Legal's requirement is not met.
- B

Isolate, snapshot, revoke, preserve
Stops the communication while keeping the instance intact, and revoking sessions handles credentials already stolen from it.
- C

Stop the instance
The near miss. Volumes survive, and memory is lost the moment it stops, which is where much of the useful evidence lives.
- D

Remove the profile
Leaves the instance talking to the attacker, and existing temporary credentials keep working until they expire.

THE SIGNAL

Revoking the role's sessions is the step people miss. Isolating the network does nothing about credentials already taken off the box.

Following a confirmed compromise of an IAM role, the security team must determine which resources the role touched over the previous 30 days, which other principals interacted with those resources, and whether the behaviour was unusual for that role.

CloudTrail, GuardDuty and Security Hub are all enabled.

Which service should the team use?

- ☐ A Amazon Detective
- ☐ B Amazon GuardDuty, filtered by the role
- ☐ C AWS Security Hub, filtered by resource
- ☐ D Amazon Inspector

◆ PAUSE AND DECIDE

Which service should the team use?

- A** Amazon Detective
Built for exactly this: a behaviour graph over CloudTrail, VPC flow logs and GuardDuty, showing what a principal touched and what is unusual for it.
- B** GuardDuty by role
Shows findings involving that role. It does not build the surrounding picture of everything the role did or who else was involved.
- C** Security Hub by resource
Aggregates findings from other services. It is a queue of findings, not an investigation tool.
- D** Amazon Inspector
Finds software vulnerabilities. It has nothing to say about what a principal did.

THE SIGNAL

Detective is the only one of the four that answers what happened. The others report what was found.

A company deploys container images to ECS from ECR. A critical vulnerability reached production last month inside a base image. The security team wants vulnerabilities identified before images are deployed, and continuously afterwards as new CVEs are published. There are 400 images across 30 repositories.

What should the solutions architect recommend?

- ☐ A Amazon Inspector with enhanced scanning on ECR, and a pipeline gate on scan results
- ☐ B GuardDuty Runtime Monitoring on the ECS tasks
- ☐ C Amazon Macie scanning the image layers in S3
- ☐ D A weekly manual review of base image versions

◆ PAUSE AND DECIDE

What should the solutions architect recommend?

- A** Inspector enhanced scanning plus a gate
Scans on push and rescans continuously as new CVEs appear, so an image clean last week is re-flagged today. The gate stops the deploy.
- B** Runtime Monitoring
Detects malicious behaviour at runtime, which is after deployment and after exploitation. The requirement is before.
- C** Macie on image layers
Macie classifies sensitive data. It does not identify software vulnerabilities, and image layers are not its target.
- D** Weekly manual review
400 images across 30 repositories, reviewed by hand, weekly. It misses the before-deployment requirement entirely.

THE SIGNAL

Continuously afterwards is the second requirement. A scan at build time alone goes stale the moment a new CVE is published.

What to carry out of this module

- ◆ **A protection plan launched after you enabled GuardDuty stays off.** Enabled and healthy is not the same as complete.
- ◆ **Extended Threat Detection turns eight medium findings into one critical incident,** with a timeline and MITRE mapping.
- ◆ **Suppression removes a finding from every downstream consumer,** including attack sequence correlation.
- ◆ **Contain without destroying:** isolate, snapshot, revoke sessions. Terminating ends the incident and the investigation.

ON THE EXAM

Detective does not detect. It explains a finding something else produced, and that is the most commonly confused name here.